

Pramo Jewels

Authentication API Guide

Document ID: PJ-AUTHAPI-001

Version: 1.0

Status: Draft

Field	Value
Project	Pramo Jewels Premium E-Commerce Platform
Purpose	Define authentication endpoints, token lifecycle and security requirements
Audience	Backend, Frontend, Mobile Developers, QA
Version	1.0

Authentication Endpoints

Method	Endpoint	Description	Auth
POST	/api/v1/auth/register	Register new customer	No
POST	/api/v1/auth/verify-otp	Verify registration OTP	No
POST	/api/v1/auth/login	Email/phone login	No
POST	/api/v1/auth/logout	Invalidate session token	Yes
GET	/api/v1/auth/me	Current authenticated user	Yes
POST	/api/v1/auth/refresh	Refresh access token	Yes
POST	/api/v1/auth/forgot-password	Request password reset	No
POST	/api/v1/auth/reset-password	Reset password	No
PATCH	/api/v1/auth/change-password	Change password	Yes

Authentication Flow

Register → OTP Verification → Login → Access Protected APIs → Refresh Token (if applicable) → Logout.

Authorization

Use Laravel Sanctum bearer tokens. Protect routes with role-based middleware for Customer, Admin, Support and Super Admin.

Headers

Authorization: Bearer , Content-Type: application/json, Accept: application/json.

Password Policy

Minimum 8 characters, uppercase, lowercase, number and special character. Passwords stored using secure hashing algorithms.

Session Management

Invalidate tokens on logout, optional device/session management, configurable inactivity timeout and forced logout after credential changes.

Security Controls

Rate limiting, brute-force protection, account lockout after repeated failures, CSRF protection where applicable, HTTPS-only communication.

Response Standards

Return consistent JSON with success, message, data and error objects. Never expose sensitive authentication details.

Audit Logging

Record login attempts, password changes, OTP verification, failed logins and administrative authentication events.

Future Enhancements

Support MFA, passkeys/WebAuthn, social login and adaptive authentication without breaking existing API contracts.